

NARRATIVA EXPLICATIVA

La Encuesta de Madurez LINDDUN en Contexto

Por qué este instrumento importa, y por qué ahora

"En el principio era el dato. Y el dato estaba con la organización. Y la organización era el dato. Hasta que llegó el RGPD y preguntó: '¿y quién te ha dado permiso?'"

Prólogo: El Estado de la Privacidad en España en 2026

Hay una paradoja en el corazón de la privacidad corporativa española que merece ser nombrada antes de comenzar. Las organizaciones españolas —públicas y privadas— han invertido en los últimos ocho años cantidades ingentes en documentación de cumplimiento del RGPD: registros de actividades, políticas de privacidad, contratos de encargado del tratamiento, designaciones de DPO. El resultado es, en muchos casos, una arquitectura documental impresionante que descansa sobre una infraestructura técnica y organizativa que no siempre la respalda.

Es como construir la cubierta de un libro sin haber escrito los capítulos interiores.

La multa de 10,04 millones de euros impuesta a AENA en noviembre de 2025 por la Agencia Española de Protección de Datos es el símbolo perfecto de esta paradoja. No fue una empresa pequeña que ignoró el RGPD. Fue una de las mayores infraestructuras críticas del país, que consultó a la AEPD en dos ocasiones, que presentó evaluaciones de impacto, que argumentó el consentimiento de los pasajeros. Y que, a pesar de todo ello, no había realizado una EIPD válida antes de desplegar reconocimiento facial biométrico 1:N en ocho aeropuertos.

El problema no fue la ausencia de documentos. Fue la ausencia de análisis real de amenazas de privacidad desde el diseño del sistema.

Aquí es donde entra el marco LINDDUN/LIINE4DU. Y ahí es donde entra esta encuesta.

Capítulo I: LINDDUN Como Lenguaje Común

Imagine que a un equipo de ingenieros, juristas, especialistas en experiencia de usuario y directivos de negocio les pidiera que evaluaran los riesgos de privacidad de un nuevo sistema de análisis de comportamiento de clientes. Cada uno llegaría al debate con su propio vocabulario, sus propios marcos de referencia y sus propios puntos ciegos.

El ingeniero hablaría de vectores de ataque y superficies de exposición.

El jurista hablaría de bases legitimadoras y proporcionalidad.

El especialista en UX hablaría de transparencia y confianza del usuario.

El directivo de negocio hablaría de valor del dato y ventaja competitiva.

Y todos tendrían razón. Y ninguno de ellos tendría una conversación común con los demás.

LINDDUN es, antes que cualquier otra cosa, un **lenguaje común** para hablar de privacidad en organizaciones complejas. Sus siete indicadores (Linking, Identifying, Non-repudiation, Detecting, Data Disclosure, Unawareness, Non-compliance) no son categorías técnicas para ingenieros: son categorías de daño a personas reales, expresadas en un vocabulario lo suficientemente preciso como para ser analizable y lo suficientemente comprensible como para ser comunicable.

Cuando hablamos de **Linking**, no estamos hablando de una base de datos: estamos hablando del riesgo de que alguien aprenda más sobre una persona de lo que esa persona ha consentido revelar, combinando datos de distintas fuentes que, por separado, son inocuos.

Cuando hablamos de **Detecting**, no estamos hablando de un sensor: estamos hablando del riesgo de que la mera presencia de una persona en un lugar, a una hora, haciendo algo, quede registrada de forma que defina una narrativa sobre ella sin su conocimiento ni consentimiento.

Cuando hablamos de **Non-repudiation**, no estamos hablando de logs de auditoría: estamos hablando del riesgo de que una persona sea incapaz de negar razonablemente una acción, una creencia o una presencia porque los sistemas que la rodeaban acumularon evidencias que no tenían por qué acumular.

Esta distinción —entre la dimensión técnica y la dimensión de daño a personas— es la que hace de LINDDUN un marco genuinamente útil en 2026. No porque sea el más sofisticado técnicamente (hay herramientas de modelado de amenazas más potentes), sino porque es el más eficaz para conectar la ingeniería de sistemas con el derecho fundamental a la privacidad.

Capítulo II: Por Qué una Encuesta y No una Auditoría

La decisión de instrumentalizar el marco LINDDUN en forma de encuesta de madurez organizacional, y no de auditoría técnica formal, responde a tres consideraciones estratégicas.

Primera consideración: La auditoría mide el pasado; la encuesta orienta el futuro. Una auditoría técnica de privacidad examina sistemas existentes, contrastándolos con criterios normativos. Es esencial para la verificación de cumplimiento. Pero no genera, por sí misma, el aprendizaje organizacional necesario para que ese cumplimiento se convierta en capacidad institucional. La encuesta de madurez, al pedir a la organización que se sitúe en una escala descriptiva, genera conciencia, vocabulario compartido y, crucialmente, señala la dirección del viaje.

Segunda consideración: Las organizaciones aprenden más de las preguntas que de las respuestas. El mayor valor de esta encuesta no está en el Índice de Madurez Global que calcula al final. Está en las conversaciones que genera durante su aplicación. Cuando el CISO y el DPO descubren que tienen percepciones completamente distintas sobre el nivel de madurez en el módulo de Unawareness, eso ya es información crítica sobre la organización. La encuesta es, en este sentido, un instrumento de alineamiento organizacional tanto como de diagnóstico.

Tercera consideración: La proporcionalidad de los instrumentos. La mayoría de las organizaciones españolas con responsabilidad en materia de protección de datos no son corporaciones multinacionales con equipos dedicados de privacy engineering. Son PYMES, Administraciones Públicas

locales, cooperativas, centros educativos, clínicas. Para ellos, una auditoría técnica completa sería un instrumento desproporcionado y, probablemente, desalentador. Una encuesta bien diseñada les permite tomar conciencia de su situación, priorizar esfuerzos y avanzar de forma gradual y realista.

Capítulo III: El Tono y el Por Qué del Tono

El lector habrá advertido que el tono de esta encuesta no es el habitual en los documentos de cumplimiento corporativo. Las preguntas no se formulan con la asepsia técnica de un cuestionario de auditoría, sino con algo que podríamos llamar **ironía compasiva**: el reconocimiento de que la brecha entre el ideal regulatorio y la realidad organizativa no siempre es producto de la negligencia o la mala fe, sino de la complejidad, los recursos limitados, la urgencia de otras prioridades y, a veces, de la simple humanidad de los que tienen que implementar estos marcos.

La opción A de cada pregunta no ridiculiza a quien la selecciona: reconoce una realidad que, en alguna medida, comparte la mayoría de las organizaciones. Su formulación ligeramente irónica tiene un propósito pedagógico preciso: **hacer visible, sin hacer daño**, la distancia que existe entre la práctica habitual y el nivel recomendado.

Esta es una diferencia filosófica fundamental respecto a los instrumentos de auditoría tradicionales. La encuesta no busca señalar culpables ni calcular multas potenciales. Busca crear las condiciones psicológicas y organizativas para que las personas que la completan se vean reflejadas con honestidad, sin el mecanismo de defensa que activa el lenguaje de la sanción.

Capítulo IV: El Contexto Español en 2026

España ocupa en 2026 una posición singular en el ecosistema europeo de la privacidad. Es el país de la UE con mayor densidad de Delegados de Protección de Datos por habitante, gracias en parte a la amplitud del art. 34 LOPDGDD que hace obligatorio el DPO para un conjunto de supuestos más amplio que el mínimo del RGPD. La AEPD es, junto a la DPC irlandesa y la CNIL francesa, una de las autoridades de control con mayor actividad sancionadora y mayor producción doctrinal de Europa.

Y, sin embargo, los datos del Observatorio de la Privacidad del ISMS Forum y los informes del INCIBE sobre el estado de la ciberseguridad y la privacidad en el tejido empresarial español muestran un panorama de notable heterogeneidad: las grandes corporaciones y la Administración General del Estado han alcanzado niveles de madurez equivalentes a sus homólogos europeos, mientras que la PYME y la Administración Local acusan una brecha de capacidades que el incremento del volumen de sanciones no ha logrado, por sí solo, reducir.

Esta heterogeneidad es el contexto en el que nace esta encuesta. No está diseñada para los que ya tienen su LINDDUN MAESTRO integrado en su pipeline DevSecOps y su Privacy SOC operativo las 24 horas. Está diseñada para la organización que tiene claro que debería hacer algo más, pero no sabe exactamente qué, ni por dónde empezar.

Capítulo V: El Momento Post-AI Act

La entrada en vigor de las prohibiciones del AI Act en febrero de 2025 y la aplicación progresiva de sus obligaciones a lo largo de 2025 y 2026 han añadido una nueva dimensión de urgencia al análisis de privacidad de las organizaciones españolas. Los sistemas de IA de alto riesgo requieren, entre otras cosas, una evaluación de impacto en derechos fundamentales (Art. 27 AI Act) que es, en esencia, una EIPD extendida.

La integración de LINDDUN en los procesos de evaluación de sistemas de IA no es ya una opción avanzada para *privacy engineers* sofisticados: es una necesidad operativa para cualquier organización que despliegue sistemas de IA con efectos sobre personas. El marco LINDDUN ha sido extendido formalmente para incorporar las amenazas específicas de los sistemas de IA Generativa (los seis *Contextual Attribute Modifications* o CAMs identificados por KU Leuven y Huawei en 2026), y la AEPD ha publicado guías específicas para la evaluación de riesgos de privacidad en sistemas de Machine Learning.

Esta encuesta, que incluye un módulo específico sobre tecnología e IA (M10), está diseñada para acompañar a las organizaciones en ese tránsito. No como herramienta de certificación —para eso hay otros instrumentos—, sino como espejo diagnóstico que permita a cada organización saber en qué punto del viaje se encuentra.

Epílogo: Una Reflexión Para el Que Llega al Final

Si ha completado esta encuesta con honestidad, es probable que haya descubierto algunas incomodidades. Algunos ítems donde la respuesta era claramente la A o la B, cuando todos esperaban que fuera la D o la E. Algunos módulos donde la puntuación ha resultado más baja de lo que intuición hubiera indicado.

Bien. Esa incomodidad es el principio de algo.

La privacidad no es una casilla que se marca en una lista de cumplimiento normativo. Es una disciplina de diseño, un conjunto de prácticas organizativas y, en última instancia, una opción ética sobre qué tipo de relación queremos mantener con las personas cuyos datos tratamos. Una relación de respeto a su autonomía, de transparencia sobre nuestros propósitos, de austeridad en la recopilación de información que no necesitamos.

El marco LINDDUN, en su formulación más profunda, no es un método de análisis de riesgos: es una forma de mirar los sistemas que diseñamos desde los ojos de las personas que los usan, padecen o sufren. Cuando un ingeniero añade un nuevo campo a una base de datos, LINDDUN le recuerda que ese campo es, potencialmente, un fragmento de la biografía de alguien. Cuando un directivo aprueba un sistema de videovigilancia, LINDDUN le recuerda que cada cámara dibuja, hora a hora, un retrato involuntario de quienes pasan bajo ella.

Esa mirada es lo que esta encuesta intenta transmitir. Con la esperanza de que, al menos en algunas organizaciones, cambie algo más que los formularios.

*Narrativa elaborada como material introductorio del Kit de Encuesta LINDDUN/LIINE4DU 2025–2026.
Puede reproducirse libremente con atribución. Versión 1.0 — Abril 2026.*